



ARKA HEALTH, INC.

HIPAA SECURITY RISK ASSESSMENT REPORT (2026)

Initial enterprise risk analysis under 45 C.F.R. § 164.308(a)(1)(ii)(A) — NIST SP 800-30 methodology

ARKA-RDY-001 · Version 1.0 · Confidential — Restricted Distribution

Document No.	ARKA-RDY-001
Version	1.0
Effective Date	June 10, 2026
Last Reviewed	June 10, 2026
Document Owner	Arri Kanna, Founder & Chief Executive Officer — Privacy & Security Officer
Approved By	Arri Kanna, Founder & Chief Executive Officer
Classification	Confidential — Restricted Distribution
Review Cycle	Annual, and upon any material change in operations, systems, or law

This document contains confidential and proprietary information of ARKA Health, Inc. (“ARKA”). It is furnished for informational and compliance purposes, may not be reproduced or disclosed to any third party without the prior written consent of ARKA, and must be returned or destroyed upon request. Nothing in this document constitutes legal advice.

1. EXECUTIVE SUMMARY

This report documents the initial enterprise security risk analysis of ARKA Health, Inc., performed by the Security Officer in accordance with ARKA-SEC-002 and NIST SP 800-30 (Rev. 1). The assessment covered the ARKA Platform and all supporting systems identified in the technology asset inventory as of June 2026. The central finding is that **ARKA presently creates, receives, maintains, and transmits no Protected Health Information**: the public demonstration environment operates exclusively on synthetic data (ARKA-DEMO-001), and no business associate agreement is yet in effect. The risks assessed are accordingly (a) present risks to Company confidential information and platform integrity, and (b) prospective risks to ePHI under the planned production architecture, assessed now so that remediation precedes the first PHI-bearing engagement.

Eleven risk scenarios were assessed. After application of existing controls, no scenario was rated Critical; three were rated High and are subject to the remediation plan in Section 5, each with a named owner and a due date in advance of production PHI onboarding.

2. SCOPE AND METHOD

- **Assets reviewed:** application tier (Next.js services on Vercel), managed PostgreSQL and authentication (Supabase), AWS account (target scaling architecture), GitHub organization (source, CI/CD), corporate SaaS, founder endpoints, and the public demonstration environment.
- **Data flows mapped:** website/demo traffic (synthetic data only); planned production flows — EHR-launched SMART on FHIR sessions, FHIR R4 prefetch into CDS services, CDS Hooks card responses, and payer-facing prior-authorization documentation flows (Da Vinci CRD/DTR/PAS).
- **Method:** threat–vulnerability pairing per asset class; likelihood and impact on five-point scales; inherent rating before controls; residual rating after controls documented in the ARKA-SEC series; treatment per ARKA-SEC-002, § 2.

3. RISK REGISTER (RESIDUAL)

#	Risk scenario	Likelihood	Impact	Residual	Primary controls
1	Credential phishing of founder/admin account leading to source or infrastructure compromise	Possible	Major	High	MFA with hardware keys (SEC-003); alerting (SEC-005); R-1 below
2	Supply-chain vulnerability in third-party dependency reaches production	Possible	Moderate	Medium	CI dependency audit, pinned lockfiles, release gating (SEC-010)
3	Misconfiguration of cloud tenancy (public bucket, permissive policy) exposing confidential data	Possible	Major	High	IaC review, CIS hardening (SEC-001); R-2 below
4	Ransomware/destructive compromise of production data tier	Unlikely	Severe	Medium	Immutable cross-region backups, restore testing (SEC-007)
5	PHI submitted by a user into the public demo in violation of posted	Possible	Moderate	Medium	No-PHI notices, input constraints, purge

#	Risk scenario	Likelihood	Impact	Residual	Primary controls
	terms				procedure (DEMO-001)
6	Key-person dependency: single individual holds privileged access and program knowledge	Likely	Moderate	High	Documented runbooks; R-3 below
7	Vendor concentration: outage or security failure of a Tier 1 provider	Possible	Moderate	Medium	Vendor monitoring (SEC-009); recovery objectives (SEC-007)
8	Tenant-isolation defect in multi-tenant data layer (future production)	Unlikely	Severe	Medium	Row-level security, authorization tests in CI (SEC-003, SEC-010)
9	Loss/theft of an endpoint containing cached confidential data	Possible	Minor	Low	FDE, remote wipe, no-local-PHI rule (SEC-012)
10	Insider misuse of access to confidential or (future) Customer data	Unlikely	Major	Medium	Least privilege, immutable logging, sanctions (SEC-003/005/008)
11	Inadequate audit evidence at first external examination	Possible	Moderate	Medium	Evidence-generation requirements (SEC-001, § 2(e)); RDY-002 plan

4. CURRENT-STATE OBSERVATIONS

- Encryption in transit and at rest is provided by default across the current provider stack; HSTS is enforced on public endpoints.
- Source control enforces protected branches with CI gates, including compliance test suites, scope-boundary linting, and secret scanning.
- The demonstration environment carries conspicuous synthetic-data notices and contains no mechanism for bulk clinical data ingestion.
- Formal quarterly access reviews, the first annual penetration test, centralized log aggregation with alerting coverage targets, and the first full restore exercise remain open items, sequenced below.

5. REMEDIATION PLAN (HIGH RISKS)

ID	Action	Risk addressed	Owner	Due
R-1	Complete migration of all administrative accounts to phishing-resistant FIDO2 hardware keys; disable all fallback factors weaker than platform passkeys	#1	Security Officer	July 31, 2026
R-2	Adopt automated cloud-posture scanning against CIS Benchmarks for AWS/Vercel/Supabase configuration; remediate all High findings	#3	Security Officer	Aug. 31, 2026

ID	Action	Risk addressed	Owner	Due
R-3	Document and test deputy procedures: sealed credential escrow, second authorized administrator, runbook for assumption of operations	#6	CEO	Sept. 30, 2026
R-4	Commission first independent penetration test (pre-production scope)	#1, #3, #8	Security Officer	Oct. 31, 2026
R-5	Stand up centralized log aggregation with alert rules of SEC-005, § 4 verified by simulation	#1, #10	Security Officer	Sept. 30, 2026

6. ACCEPTANCE AND NEXT ASSESSMENT

The residual Medium and Low risks identified herein are accepted pending the remediation schedule above. This analysis shall be refreshed upon any trigger in ARKA-SEC-002, § 3, upon execution of the Company's first BAA (which shall be treated as a material change), and in any event no later than June 2027.

DOCUMENT CONTROL & REVISION HISTORY

Version	Date	Author / Reviewer	Description of Change
0.9	May 22, 2026	A. Kanna (drafting); external review pending	Initial draft circulated for internal review and counsel comment.
1.0	June 10, 2026	A. Kanna, Privacy & Security Officer	Adopted as effective policy of ARKA Health, Inc. by written approval of the undersigned officer.

ADOPTION AND APPROVAL

The undersigned, being the duly designated Privacy Officer and Security Officer of ARKA Health, Inc., hereby adopts this document as an official policy of the Company, effective as of the Effective Date set forth on the cover page hereof. This document shall be reviewed no less frequently than annually and upon any material change to the Company's operations, information systems, or applicable law, and may be amended only in accordance with ARKA-GOV-001 (Information Security & Compliance Program Charter).

ARKA HEALTH, INC.

By: _____

Name: Arri Kanna

Title: Founder & Chief Executive Officer; Privacy & Security Officer

Date: June 10, 2026